

UNIT-I

Introduction to System Security

Definition of System Security:

Computer Security can be defined as technological and managerial procedures applied to computer systems to ensure the availability, integrity, and confidentiality of the information managed by the computer. It means the protection of Integrity, Availability and Confidentiality of Computer Assets and Services from associated Threats and vulnerabilities. Security is divided into two categories.

- (a) Computer Security and
- (b) Network Security.

In generic terms, computer security is the process of securing a single, standalone computer; while network security is the process of securing an entire network of computers.

a) **Computer Security:** Technology and managerial procedures applied to computer systems to ensure the availability, integrity, and confidentiality of the data managed by the computer.

b) **Network Security:** Protection of networks and their services from unauthorised modification, destruction, or disclosure and provision of assurance that the network performs its critical functions correctly and there are no harmful side effects. The major weaknesses in a computer system pertain to hardware, software, and data. However, other components of the computer systems may also be targeted.

System Security Goals,

The goals of computer security are integrity, confidentiality, and availability of the information managed by the computer system. The relationship among the three is shown in Figure 1.

1.2.1 Integrity

The data Integrity in computer security deals with the knowledge that data has not been modified. Data Integrity is related to data accuracy, but integrity and accuracy are not the same. For example, if information is entered incorrectly, it will remain incorrect. So, it is possible to have Data Integrity without Data Accuracy. Integrity means preventing unauthorised modification. To preserve the integrity of an item means that the item is unmodified, precise, accurate, modified in an acceptable way by authorised people, or consistent.

1.2.2 Confidentiality

Confidentiality means preventing unauthorised access. It ensures that only the authorised person accesses the computer system. Not all data available on the computer falls in the category of confidential data. There is data that can be made public and there is data that is considered sensitive. It is this critical or sensitive data that will require confidentiality. Data confidentiality cannot be enforced unless data integrity is present. The following items could require data confidentiality: credit card files, medical records, personnel data, mission-critical data, and R&D data etc.

1.2.3 Availability

There is no point in making the computer system so secure that no users can access the data they need to perform their jobs effectively. The system should be accessible to authorised persons at appropriate times.

A computer system is available if.

- The response time is acceptable.
- There is a fair allocation of resources.
- Fault tolerance exists.
- It is user friendly.
- Concurrency control and deadlock management exists. Terms like concurrency control and deadlock management will be discussed in the operating system course.

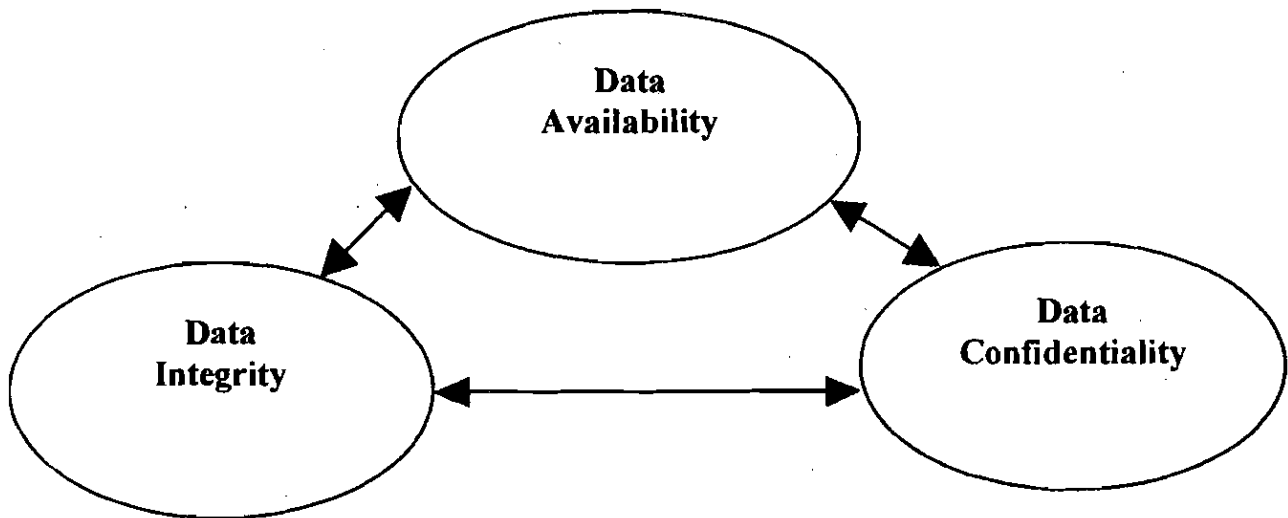


Figure 1: Relationship between Confidentiality, Integrity, and Availability

System Security characteristics and importance of system security,

Protection of information has been a major challenge since the beginning of the computer age. The computer security problem has grown with the computer industry, the computer itself was not really part of the security problem or its solution.

Connecting computers introduces a need for communication security (often utilising cryptography) to prevent the possibility of an attack. Connecting computers gives them greater accessibility, which increases computer security problems.

Computer security attempts to ensure the confidentiality, integrity, and availability of the computing system's components. The principal components of a computing system subject to attacks are: hardware, software and data. These three components and the communications among them is the basis of computer vulnerabilities. Attackers can devise attacks that exploit these vulnerabilities. There are basically four kinds of attacks on computing systems: interception, interruption, modification, and fabrication.

One of the ways to identify security problems is by means of risk analysis. Risk analysis involves determining:

- What you need to protect,
- What you need to protect it from,
- And how to protect it.

It is the process of examining all your risks and ranking those risks by level of severity. There are three major steps in risk analysis, namely:

- Identifying the assets (what are you protecting)
- Identifying the threats (against what)
- Identifying impact.

1.3.1 Identifying the Assets

Hardware: CPUs, boards, keyboards, terminals, workstations, personal computers, printers, disk drives, communication lines, terminal servers, routers, **Management** hubs, gateways, servers, modems, etc.

Software: source programs, object programs, utilities, diagnostic programs, operating systems, communications program, firewall software, IDS (Intrusion Detection System) software etc.

Data: during execution, store on-line, archive off-line, backup, audit logs, databases, in transit over communication media etc.

People: user, people needed to run systems.

Documentation: on programs, hardware, systems, local administrative procedures.

Supplies: paper, forms, ribbons, floppy diskettes, magnetic media. Based on the above, asset inventory call be created with the following component for each asset:

- Designated owner
- General support system or critical major application
- Physical logical location.

1.3.2 Identifying the Threats

Once the assets requiring protection are identified, it is necessary to identify threats to those assets. The threats can be then evaluated to determine what potential for loss exists.

There are two basic type of threats: accidental threats and intentional threats. Accidental threats can lead to exposure of confidential information or causing an illegal system state to occur due to modification of information. An intentional threat is an action performed by an entity with the intention to violate security. And this includes destruction, modification, fabrication, interruption, or interception of data.

In general, threats to an asset should be considered in terms of the availability, confidentiality, and integrity of the asset. The possible threats to a computer system can be:

- Unauthorised Access
- Disclosure of information
- Denial of service.

1.3.3 Identifying the Impact

After identifying the assets and threats, the impact of security attack should be assessed. The process includes the following tasks.

- Identifying the vulnerabilities of the system.
- Analysing the possibility of threats to exploit these vulnerabilities.
- Assessing the consequences of each threat; ,
- Estimating the cost 'of each attack.
- Estimating the cost of potential counter measure, and
- Selecting the optimum and cost-effective security system.

The consequence of a threat materialised in an organisation could result in one or more impacts. For example, an impact can be:

- Infringement of privacy
- Financial loss
- Disruption of activities.

Principle of easiest penetration:

- An intruder must be expected to use any available means of penetration.
- The penetration may not necessarily be by the most obvious means, nor is it necessarily the one against which the most solid defence has been installed.
- And it certainly does not have to be the way we want the attacker to behave.
- Therefore, we must consider every possible means that an intruder or hacker could approach a data system.

Three pillars of security CIA (Confidentiality, Integrity, and Availability)

Basic introduction of attacks:

When there is an unauthorized system/network access by a third party, we term it as a cyber-attack. The person who carries out a cyberattack is termed as a hacker/attacker.

Cyber-attacks have several negative effects. When an attack is carried out, it can lead to data breaches, resulting in data loss or data manipulation. Organizations incur financial losses, customer trust gets hampered, and there is reputational damage. To put a curb on cyberattacks, we implement cybersecurity. Cybersecurity is the method of safeguarding networks, computer systems, and their components from unauthorized digital access.

The COVID-19 situation has also had an adverse impact on cybersecurity. According to Interpol and WHO, there has been a notable increase in the number of cyberattacks during the COVID-19 pandemic.

Now that you know what a cyber-attack is, let look at the different types of cyberattacks.

Types of Cyber Attacks

There are many varieties of cyber-attacks that happen in the world today. If we know the various types of cyberattacks, it becomes easier for us to protect our networks and systems against them. Here, we will closely examine the top ten cyber-attacks that can affect an individual, or a large business, depending on the scale.

Let's start with the different types of cyberattacks on our list:

1. Malware Attack

This is one of the most common types of cyberattacks. "Malware" refers to malicious software viruses including worms, spyware, ransomware, adware, and trojans. The trojan virus disguises itself as legitimate software. Ransomware blocks access to the network's key components, whereas Spyware is software that steals all your confidential data without your knowledge. Adware is software that displays advertising content such as banners on a user's screen.

Malware breaches a network through a vulnerability. When the user clicks a dangerous link, it downloads an email attachment or when an infected pen drive is used. Let's now look at how we can prevent a malware attack:

- Use antivirus software. It can protect your computer against malware. Avast Antivirus, Norton Antivirus, and McAfee Antivirus are a few of the popular antivirus software.
- Use firewalls. Firewalls filter the traffic that may enter your device. Windows and Mac OS X have their default built-in firewalls, named Windows Firewall and Mac Firewall.
- Stay alert and avoid clicking on suspicious links.
- Update your OS and browsers, regularly.

2. Phishing Attack

Phishing attacks are one of the most prominent widespread types of cyberattacks. It is a type of social engineering attack wherein an attacker impersonates to be a trusted contact and sends the victim fake mails.

Unaware of this, the victim opens the mail and clicks on the malicious link or opens the mail's attachment. By doing so, attackers gain access to confidential information and account credentials. They can also install malware through a phishing attack.

Phishing attacks can be prevented by following the below-mentioned steps:

- Scrutinize the emails you receive. Most phishing emails have significant errors like spelling mistakes and format changes from that of legitimate sources.
- Make use of an anti-phishing toolbar.
- Update your passwords regularly.

3. Password Attack

It is a form of attack wherein a hacker cracks your password with various programs and password cracking tools like Aircrack, Cain, Abel, John the Ripper, Hashcat, etc. There are different types of password attacks like brute force attacks, dictionary attacks, and keylogger attacks.

Listed below are a few ways to prevent password attacks:

- Use strong alphanumeric passwords with special characters.
- Abstain from using the same password for multiple websites or accounts.
- Update your passwords; this will limit your exposure to a password attack.
- Do not have any password hints in the open.

4. Man-in-the-Middle Attack

A Man-in-the-Middle Attack (MITM) is also known as an eavesdropping attack. In this attack, an attacker comes in between a two-party communication, i.e., the attacker hijacks the session between a client and host. By doing so, hackers steal and manipulate data.

As seen below, the client-server communication has been cut off, and instead, the communication line goes through the hacker.

MITM attacks can be prevented by following the below-mentioned steps:

- Be mindful of the security of the website you are using. Use encryption on your devices.
- Refrain from using public Wi-Fi networks.

5. SQL Injection Attack

A Structured Query Language (SQL) injection attack occurs on a database-driven website when the hacker manipulates a standard SQL query. It is carried by injecting a malicious code into a vulnerable website search box, thereby making the server reveal crucial information.

This results in the attacker being able to view, edit, and delete tables in the databases. Attackers can also get administrative rights through this.

To prevent a SQL injection attack:

- Use an Intrusion detection system, as they design it to detect unauthorized access to a network.
- Carry out a validation of the user-supplied data. With a validation process, it keeps the user input in check.

6. Denial-of-Service Attack

A Denial-of-Service Attack is a significant threat to companies. Here, attackers target systems, servers, or networks and flood them with traffic to exhaust their resources and bandwidth.

When this happens, catering to the incoming requests becomes overwhelming for the servers, resulting in the website it hosts either shut down or slow down. This leaves the legitimate service requests unattended.

It is also known as a DDoS (Distributed Denial-of-Service) attack when attackers use multiple compromised systems to launch this attack.

Let's now look at how to prevent a DDoS attack:

- Run a traffic analysis to identify malicious traffic.
- Understand the warning signs like network slowdown, intermittent website shutdowns, etc. At such times, the organization must take the necessary steps without delay.
- Formulate an incident response plan, have a checklist and make sure your team and data center can handle a DDoS attack.
- Outsource DDoS prevention to cloud-based service providers.

7. Insider Threat

As the name suggests, an insider threat does not involve a third party but an insider. In such a case; it could be an individual from within the organization who knows everything about the organization. Insider threats have the potential to cause tremendous damages.

Insider threats are rampant in small businesses, as the staff there hold access to multiple accounts with data. Reasons for this form of an attack are many, it can be greed, malice, or even carelessness. Insider threats are hard to predict and hence tricky.

To prevent the insider threat attack:

- Organizations should have a good culture of security awareness.
- Companies must limit the IT resources staff can have access to depending on their job roles.
- Organizations must train employees to spot insider threats. This will help employees understand when a hacker has manipulated or is attempting to misuse the organization's data.

8. Cryptojacking

The term Cryptojacking is closely related to cryptocurrency. Cryptojacking takes place when attackers access someone else's computer for mining cryptocurrency.

The access is gained by infecting a website or manipulating the victim to click on a malicious link. They also use online ads with JavaScript code for this. Victims are unaware of this as the Crypto mining code works in the background; a delay in the execution is the only sign they might witness.

Cryptojacking can be prevented by following the below-mentioned steps:

- Update your software and all the security apps as cryptojacking can infect the most unprotected systems.
- Have cryptojacking awareness training for the employees; this will help them detect cryptotjacking threats.
- Install an ad blocker as ads are a primary source of cryptojacking scripts. Also have extensions like MinerBlock, which is used to identify and block crypto mining scripts.

9. Zero-Day Exploit

A Zero-Day Exploit happens after the announcement of a network vulnerability; there is no solution for the vulnerability in most cases. Hence the vendor notifies the vulnerability so that the users are aware; however, this news also reaches the attackers.

Depending on the vulnerability, the vendor or the developer could take any amount of time to fix the issue. Meanwhile, the attackers target the disclosed vulnerability. They make sure to exploit the vulnerability even before a patch or solution is implemented for it.

Zero-day exploits can be prevented by:

- Organizations should have well-communicated patch management processes. Use management solutions to automate the procedures. Thus it avoids delays in deployment.
- Have an incident response plan to help you deal with a cyberattack. Keep a strategy focussing on zero-day attacks. By doing so, the damage can be reduced or completely avoided.

10. Watering Hole Attack

The victim here is a particular group of an organization, region, etc. In such an attack, the attacker targets websites which are frequently used by the targeted group. Websites are identified either by closely monitoring the group or by guessing.

After this, the attackers infect these websites with malware, which infects the victims' systems. The malware in such an attack targets the user's personal information. Here, it is also possible for the hacker to take remote access to the infected computer.

Threat:

A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.

A computer threat is a term that relates to the security of a computer system being compromised. This threat can lead to cyber-attacks and data being stolen, lost or edited. The threat could be caused by poor information security practices or a 'backdoor' in the code of the system.

Vulnerability:

A vulnerability is a weakness that can be exploited by cybercriminals to gain unauthorized access to a computer system. After exploiting a vulnerability, a cyberattack can run malicious code, install malware, and even steal sensitive data.

Vulnerabilities can be exploited by a variety of methods, including SQL injection, buffer overflows, cross-site scripting (XSS), and open-source exploit kits that look for known vulnerabilities and security weaknesses in web applications.

Vulnerability Examples

There are several different types of vulnerabilities, determined by which infrastructure they're found on. Vulnerabilities can be classified into six broad categories:

- 1. Hardware:** Any susceptibility to humidity, dust, soiling, natural disaster, poor encryption, or firmware vulnerability.
- 2. Software:** Insufficient testing, lack of audit trail, design flaws, memory safety violations (buffer overflows, over-reads, dangling pointers), input validation errors (code injection, cross-site scripting (XSS), directory traversal, email injection, format string attacks, HTTP header injection, HTTP response splitting, SQL injection), privilege-confusion bugs (clickjacking, cross-site request forgery, FTP bounce attack), race conditions (symlink races, time-of-check-to-time-of-use bugs), side channel attacks, timing attacks and user interface failures (blaming the victim, race conditions, warning fatigue).
- 3. Network:** Unprotected communication lines, man-in-the-middle attacks, insecure network architecture, lack of authentication, default authentication, or other poor network security.
- 4. Personnel:** Poor recruiting policy, lack of security awareness and training, poor adherence to security training, poor password management, or downloading malware via email attachments.
- 5. Physical site:** Area subject to natural disaster, unreliable power source, or no key card access.
- 6. Organizational:** Improper internal controls, lack of audit, continuity plan, security, or incident response plan.

System policy: Every system can be described by its requirements: statements of what the system should do and how it should do it. An operating system's security requirements are a set of well-defined, consistent, and implementable rules that have been clearly and unambiguously expressed. If the operating system is implemented to meet these requirements, it meets the user's expectations. To ensure that the requirements are clear, consistent, and effective, the operating system usually follows a stated security policy: a set of rules that lay out what is to be secured and why. We begin this chapter by studying several security policies for trusted operating systems.

SECURITY POLICIES

To know that an operating system maintains the security we expect, we must be able to state its security policy. A security policy is a statement of the security we expect the system to enforce. An operating system (or any other piece of a trusted system) can be trusted only in relation to its security policy; that is, to the security needs the system is expected to satisfy.

Military Security Policy

Military security policy is based on protecting classified information. Each piece of information is ranked at a particular sensitivity level, such as unclassified, restricted, confidential, secret, or top secret. The ranks or levels form a hierarchy, and they reflect an increasing order of sensitivity.

Commercial Security Policies

Commercial enterprises have significant security concerns. They worry that industrial espionage will reveal information to competitors about new products under development. Likewise, corporations are often eager to protect information about the details of corporate finance. So even though the commercial world is usually less rigidly and less hierarchically structured than the military world, we still find many of the same concepts in commercial security policies. For example, a large organization, such as a corporation or a university, may be divided into groups or departments, each responsible for a number of disjoint projects. There may also be some corporate-level responsibilities, such as accounting and personnel activities. Data items at any level may have different degrees of sensitivity, such as public, proprietary, or internal; here, the names may vary among organizations, and no universal hierarchy applies.

MODELS OF SECURITY

In security and elsewhere, models are often used to describe, study, or analyze a particular situation or relationship. McLean gives a good overview of models for security. In particular, security models are used to

- Test a particular policy for completeness and consistency.
- Document a policy help conceptualize and design an implementation.
- Check whether an implementation meets its requirements.

We assume that some access control policy dictates whether a given user can access a particular object. We also assume that this policy is established outside any model. That is, a policy decision determines whether a specific user should have access to a specific object; the model is only a mechanism that enforces that policy. Thus, we begin studying models by considering simple ways to control access by one user.

Multilevel Security

Ideally, we want to build a model to represent a range of sensitivities and to reflect the need to separate subjects rigorously from objects to which they should not have access. For instance, consider an election and the sensitivity of data involved in the voting process. The names of the candidates are probably not sensitive. If the results have not yet been released, the name of the winner is somewhat sensitive. If one candidate received an embarrassingly low number of votes, the vote count may be more sensitive. Finally, the way a particular individual voted is extremely sensitive. Users can also be ranked by the degree of sensitivity of information to which they can have access. For obvious reasons, the military has developed extensive procedures for securing information.

A generalization of the military model of information security has also been adopted as a model of data security within an operating system. Bell and La Padula [BEL73] were first to describe the properties of the military model in mathematical notation, and Denning first formalized the structure of this model. In 2005, Bell [BEL05] returned to the original model to highlight its contribution to computer security. He observed that the model demonstrated the need to understand security requirements before beginning system design, build security into not onto the system, develop a security toolbox, and design the system to protect itself. The generalized model is called the lattice model of security because its elements form a mathematical structure called a lattice. In this section, we describe the military example and then use it to explain the lattice model.

Lattice Model of Access Security

The military security model is representative of a more general scheme, called a lattice. The dominance relation defined in the military model is the relation for the lattice. The relation is transitive and antisymmetric. The largest element of the lattice is the classification <top secret; all compartments>, and the smallest element is <unclassified; no compartments>; these two elements respectively dominate and are dominated by all elements. Therefore, the military model is a lattice.

Many other structures are lattices. For example, we noted earlier that a commercial security policy may contain data sensitivities such as public, proprietary, and internal, with the natural ordering that public data are less sensitive than proprietary, which are less sensitive than internal. These three levels also form a lattice.

Many other structures are lattices. For example, we noted earlier that a commercial security. Policy may contain data sensitivities such as public, proprietary, and internal, with the natural ordering that public data are less sensitive than proprietary, which are less sensitive than internal. These three levels also form a lattice.

Security specialists have chosen to base security systems on a lattice because it naturally represents increasing degrees. A security system designed to implement lattice models can be used in a military environment. However, it can also be used in commercial environments with different labels for the degrees of sensitivity. Thus, lattice representation of sensitivity levels applies to many computing situations.

Basic introduction of threat, vulnerability, risk:

Threats have the potential to steal or damage data, disrupt business, or create harm in general. To keep that from happening, you need to know what cyber threats exist. In general terms, there are three categories.

- **Intentional threats:** Things like malware, ransomware, phishing, malicious code, and wrongfully accessing user login credentials are all examples of intentional threats. They are activities or methods bad actors use to compromise a security or software system.
- **Unintentional threats:** Unintentional threats are often attributed to human error. For example, let's say you forgot to lock the back door before leaving for work. While you're at the office, a thief seizes the opportunity to sneak into your home and steal your valuables. Even though you didn't mean to leave the door unlocked, the thief took advantage of your home's vulnerability. In the cybersecurity industry, someone might leave the door to the IT servers unlocked or leave sensitive information unmonitored. An employee could forget to update their firewall or anti-virus software. Current and even former employees may also have unnecessary access to sensitive data, or simply be unaware of the threats. (Which is why employee training is so important.)
- **Natural threats:** While acts of nature (floods, hurricanes, tornadoes, earthquakes, etc.) aren't typically associated with cybersecurity, they are unpredictable and have the potential to damage your assets.

To protect yourself from cyber threats, continuously monitor all data environments and use two-factor authentication. You should also teach your employees how to recognize phishing attempts and other tactics cyber criminals use to trick people into helping them gain access to sensitive data.

Vulnerability refers to a weakness in your hardware, software, or procedures. It's a gap through which a bad actor can gain access to your assets. In other words, threats exploit vulnerabilities.

Take Kaseya. The FBI described the incident as "a vulnerability in Kaseya VSA software against multiple managed service providers (MSPs) and their customers." Huntress, a cybersecurity firm, tracked 30 MSPs involved in the breach and concluded that the attack was due to an authentication bypass vulnerability in Kaseya's VSA web interface. It allowed attackers to work around authentication controls and upload malware.

You should know that small to medium-sized businesses tend to be more vulnerable to attacks. That's because few can afford a dedicated IT/security department, making it less likely that there are security procedures in place. (That said, cyber attacks affect companies of all sizes.) Companies should be aware of their threats and vulnerabilities in order to identify and respond to all of the risks. To determine the best way to approach a specific threat, perform regular threat assessments. Or try penetration testing, which recreates real-world threats to discover vulnerabilities.

Cyber risk is the intersection of assets, threats, and vulnerabilities. It's the *potential* for loss, damage, or destruction of an asset when a threat takes advantage of a vulnerability. Put another way:

Threats + Vulnerability = Risk

To determine your level of cyber risk, you must understand the types of threats that are out there and know your system's vulnerabilities. Although cybersecurity is an ever-moving target, you can keep your overall risk low. Trava has a free cyber risk check-up tool that runs a top-level scan of your domain. (The lower your score, the lower your risk.) By determining your level of risk, you can create a solid cyber risk management plan.

System security threats: A *security threat* is a malicious act that aims to corrupt or steal data or disrupt an organization's systems or the entire organization. A *security event* refers to an occurrence during which company data or its network may have been exposed. And an event that results in a data or network breach is called a *security incident*.

As cybersecurity threats continue to evolve and become more sophisticated, enterprise IT must remain vigilant when it comes to protecting their data and networks. To do that, they first have to understand the types of security threats and potential attacks they're up against.

Below are the top 10 types of information security threats that IT teams need to know about.

1. Insider threats
2. Viruses and worms
3. Botnets
4. Drive-by download attacks
5. Phishing attacks
6. DDoS
7. Ransomware
8. Exploit kits
9. Advanced persistent threat attacks
10. Malvertising

Security concepts and relationship,

